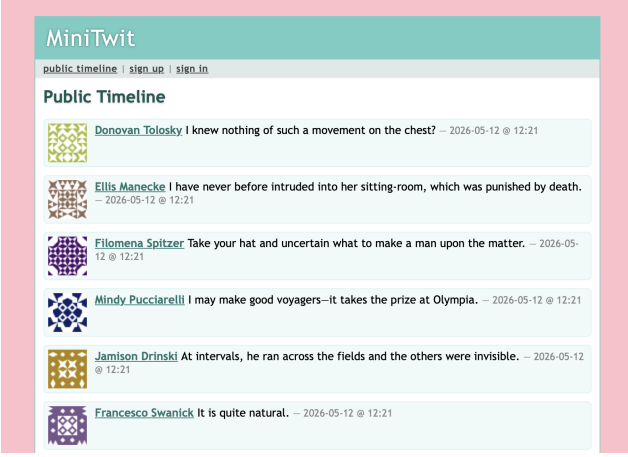
DevOps, Software Evolution and Software Maintenance, MSc



Group K - Pat Myaz

Carmen Alberte Nielsen | alcn@itu.dk
Casper Storm Frøding | csfr@itu.dk
Mads Christian Nørklit Jensen | macj@itu.dk
Mathilde Julie Gonzalez-Knudsen | mgon@itu.dk
Max Brix Koch | mbko@itu.dk

18-05-2026

Contents

1 System's Perspective **3**

1.1 Design and Architecture . . . 3

1.1.1 Sequence diagram of our system . . . 3

1.2 Dependencies . . . 3

1.3 Current State . . . 5

1.3.1 SonarQube Cloud . . . 5

1.3.2 Codacy . . . 8

1.3.3 CodeQL . . . 8

1.3.4 Trivy . . . 9

2 Process' Perspective **9**

2.1 CI/CD . . . 10

2.2 Monitoring . . . 12

2.2.1 Dashboards . . . 13

2.3 Logging . . . 16

2.3.1 What our current logging implementation is missing . . . 16

2.4 Security . . . 16

2.5 Availability . . . 17

2.5.1 Scalability . . . 17

3 Reflection Perspective **17**

3.1 Evolution and Refactoring . . . 18

3.2 Operation . . . 18

3.3 Maintenance . . . 18

4 Use of AI **18**

5 Appendix **19**

5.1 Appendix for CI/CD workflows . . . 19

5.2 Appendix for TrivyScanner summary of minitwit-mysql image vulnerabilities . . . 21

5.3 Risk Assesment . . . 21

5.3.1 Risk identification . . . 21

5.3.2 Risk Analysis . . . 23

1 System's Perspective

A description and illustration of the:

- Design and architecture of your ITU-MiniTwit systems.
- All dependencies of your ITU-MiniTwit systems on all levels of abstraction and development stages. That is, list and briefly describe all technologies and tools you applied and depend on.
- Describe the current state of your systems, for example using results of static analysis and quality assessments.

1.1 Design and Architecture

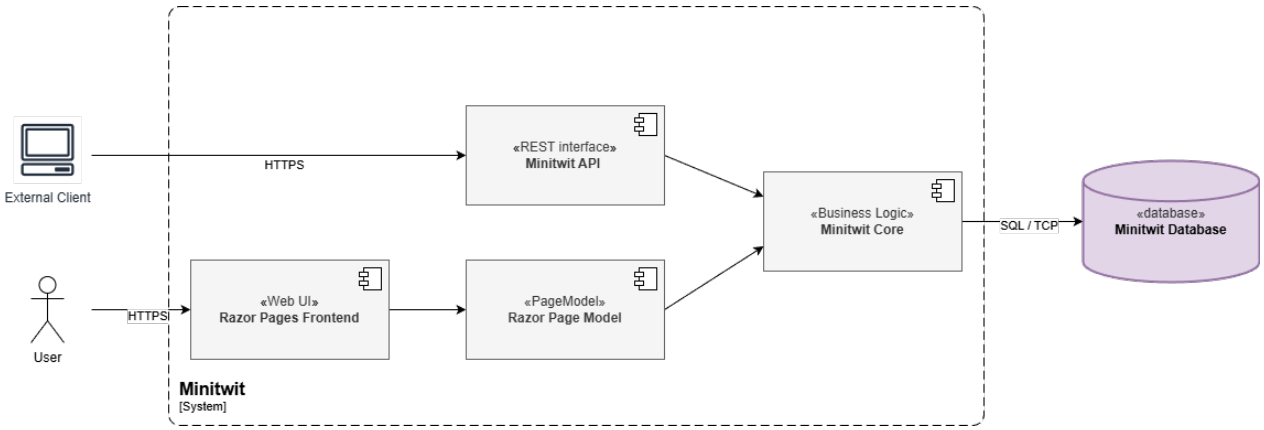


Figure 1: Component and Connectors View

1.1.1 Sequence diagram of our system

In Figure 3, we show how our system handles a post message request from a user, via the rendered Razor page.

In Figure 4, we show how our system handles a post message request, via the API.

1.2 Dependencies

Technologies:

Dependency type	Technology	Purpose
Infrastructure	DigitalOcean	Cloud Hosting Droplets and Firewall
OS	Ubuntu (ubuntu-22-04-x64)	Operating system on DigitalOcean Droplets
Orchestration	Docker Swarm	Container Clustering
Containerization	Docker	Container Runtime Environment
Containerization	Docker Compose	Multi-container configuration and local orchestration
Container Registry	DockerHub	Storing repositories of our minitwit docker images

Dependency type	Technology	Purpose
Container Hardened Images	dhi.io	Docker hardened images for .NET 10
Container Base Image	Python3.12/alpine	Lightweight runtime for Python containers
Container Base Image	mysql:8.0	MySQL base image for docker container
Container Base Image	grafana/grafana:12.1	Grafana base image for docker containers
Container Base Image	prom/prometheus:v3.5.1	Prometheus base image for docker containers
Container Base Image	docker.elastic.co/elasticsearch/elasticsearch:7.17.10	ElasticSearch base image for docker containers
Container Base Image	curlimages/curl	Curl base image for docker containers used for healthchecks
Provisioning Tool	Vagrant	Infrastructure-as-Code for VM provisioning
Provisioning Tool	DropletKit	Integration between Vagrant and DigitalOcean API
Language	ruby	Language used for Vagrant configuration
Domain Management	name.com	Domain name registration and managing
Reverse Proxy	Traefik	Load balancing and reverse proxy for routing traffic
Security	Let's Encrypt	Automated SSL/TLS certificate provisioning
Security	Fail2Ban	Protects droplets by banning malicious IPs
Scripting	bash	Shell scripts for automated tasks
Monitoring	Prometheus (Server)	Metrics collection
Monitoring	Grafana	Visualization and dashboarding of metrics and logging
Logging	ElasticSearch	Log storage, indexing and search
Runtime Framework	.NET 10	Application runtime and framework
Language	C#	Code language for Minitwit
Database	MySQL 8.0	Relation database for application data
Styling Language	CSS	Frontend styling language
Frontend Framework	Bootstrap	CSS framework for UI design
Scripting Language	JavaScript	Client-side logic and interaction
Version Control	Github	Version control platform
CI/CD	Github Actions	CI/CD workflows
Security	CodeQL	Static security analysis of code
Security	Trivy	Vulnerability scanning for containers and Dockerfiles
Analysis Tool	Dockle	Analysis of Dockerfiles
Analysis Tool	Codacy	Automated code quality analysis
Analysis Tool	SonarQube	Code quality and static analysis
Runtime Dependency	Java (JDK17)	Required runtime for SonarQube
Documentation Tool	TinyTex	Lightweight LaTeX distribution for report generation

Dependency type	Technology	Purpose
Documentation Tool	Pandoc	Document conversion and report generation
Language	Python 3	Code language for UI and API tests
Web browser	Firefox	Web browser for automated UI tests
Testing Tool	Geckodriver	WebDriver implementation for controlling Firefox in tests

.NET depencies:

Dependency type	Package	Purpose
Web Framework	ASP.NET Core	Razor Pages
API Tooling	OpenAPITools	Generating and documenting APIs
Code Analysis	.NET Analyzers	Analysing .NET code
Code Analysis	Roslynator	Linting .NET code
ORM	EntityFramework Core	Database abstraction and object-relational mapping
ORM Extension	Pomelo.EntityFrameworkCore.MySql	MySQL provider for EntityFramework Core
Monitoring	Prometheus (Client library)	Exposing application metrics
Logging Sink	Elastic.Serilog.Sinks	Sending Serilog's to ElasticSearch
Logging Library	Serilog	Structured logging and log management
Testing Framework	Xunit	Unit testing framework
Testing	Microsoft.NET.Test.Sdk	Enables running and executing tests
Testing	Microsoft.AspNetCore.Mvc.Testing	Supports integration testing of ASP.NET Core apps
Test Runner	xunit.runner.visualstudio	Runs xUnit tests in development environments

Python dependencies:

Dependency type	Package	Purpose
Testing Framework	pytest	Running and managing automated tests
Browser Automation	selenium	Automating browser interactions for testing
HTTP Client	requests	Lightweight web framework for building APIs/services
Database Driver	PyMySQL	Connecting to and interacting with MySQL databases

1.3 Current State

1.3.1 SonarQube Cloud

Figure 5 shows a summary of the issues in our codebase from SonarQube Cloud. We currently have the following types of issues:

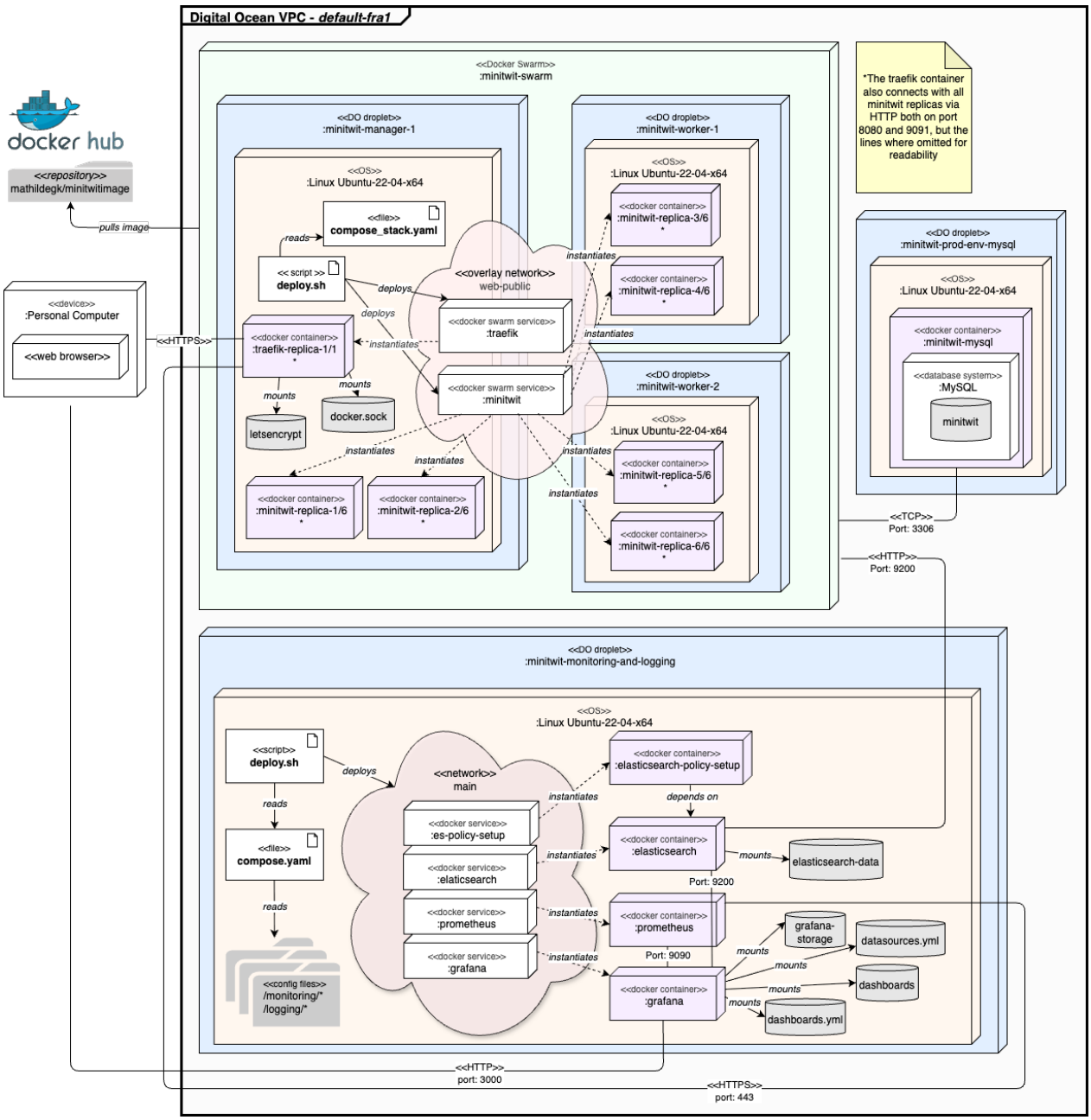


Figure 2: Allocation View

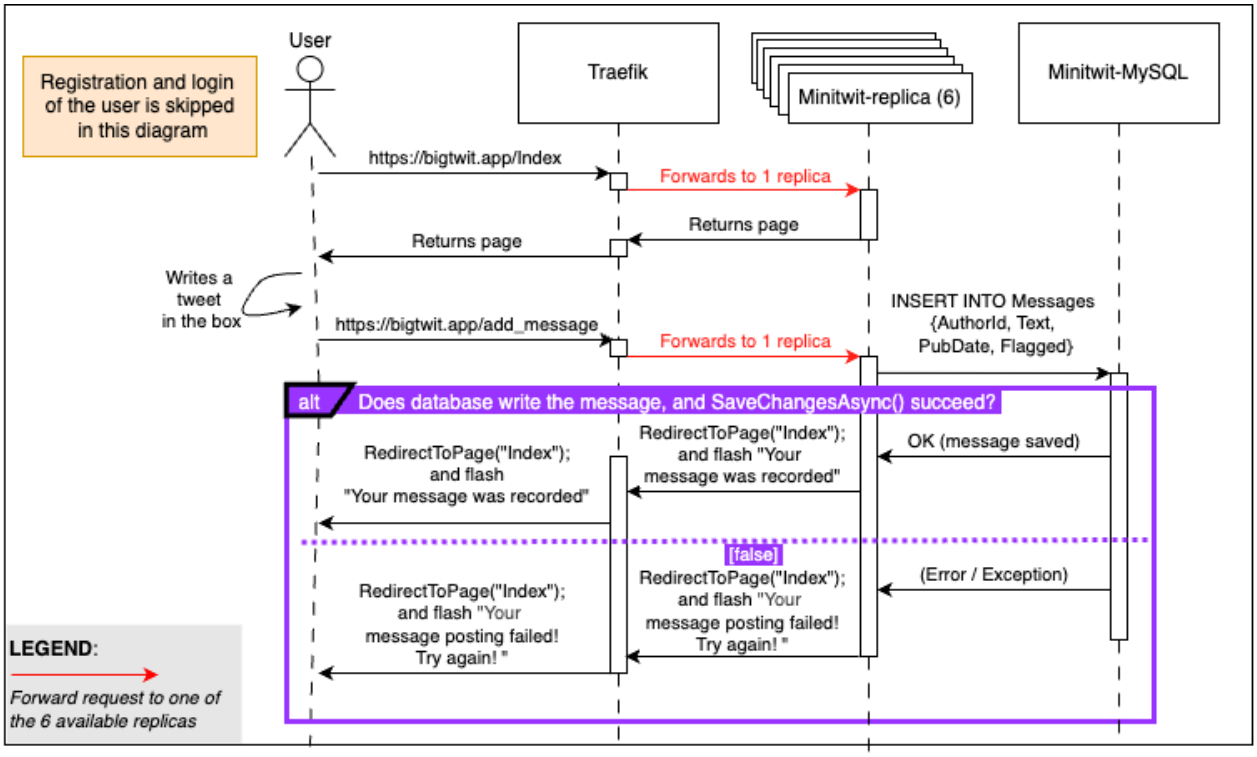


Figure 3: Sequence Diagram of a user posting a message

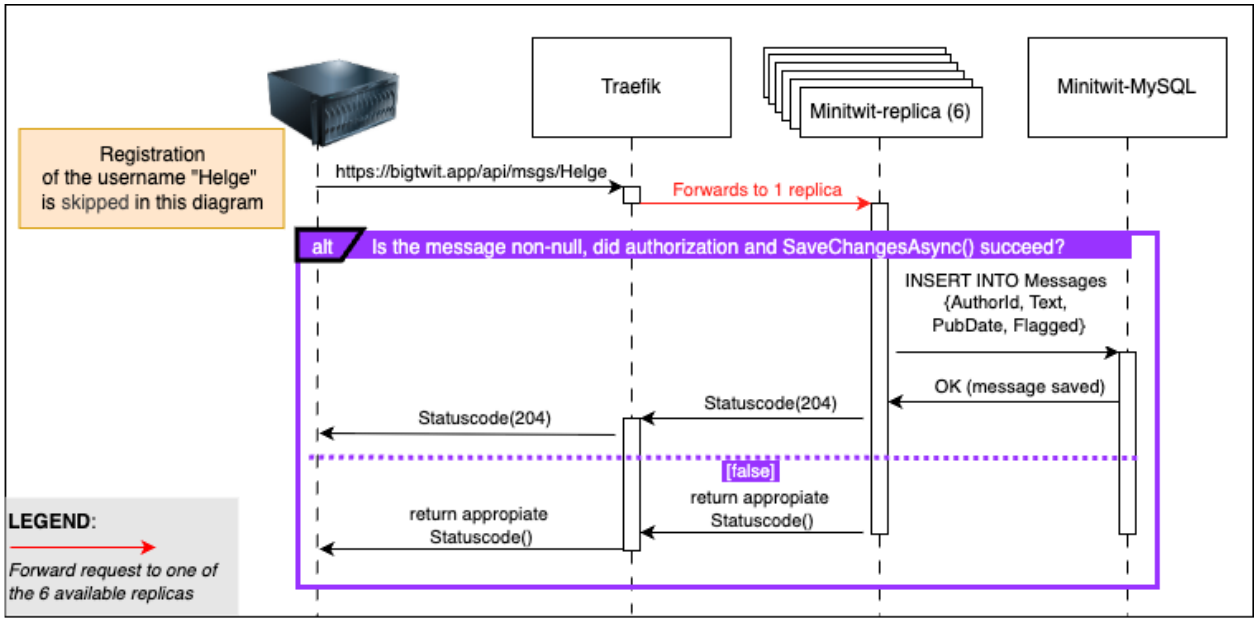


Figure 4: Sequence Diagram of an API posting a message

- **Security**: These two issues state that we should use 100.000 iterations for password hashing instead of 50.000
- **Reliability**: Relates to adding "alt" attributes to images and using double instead of single square brackets for conditionals in shell scripts
- **Maintainability**: Relates to various code smells; unused variables, naming conventions, unnecessary modifiers, comments vs. documentation, exception handling etc.

Figure 5: Summary of SonarQube Cloud analysis of entire codebase

1.3.2 Codacy

Figue 6 shows the quality evolution of our codebase according to Codacy. We currently have the following types of issues:

- **Security**, XX issues: Relates to our python tests; lack of timeouts on requests
- **Error prone**, XX issues: Relates to missing implementations of partial methods, unused variables and string operations
- **Compatibility**, XX issues: Syntax errors in our init_db.sql script

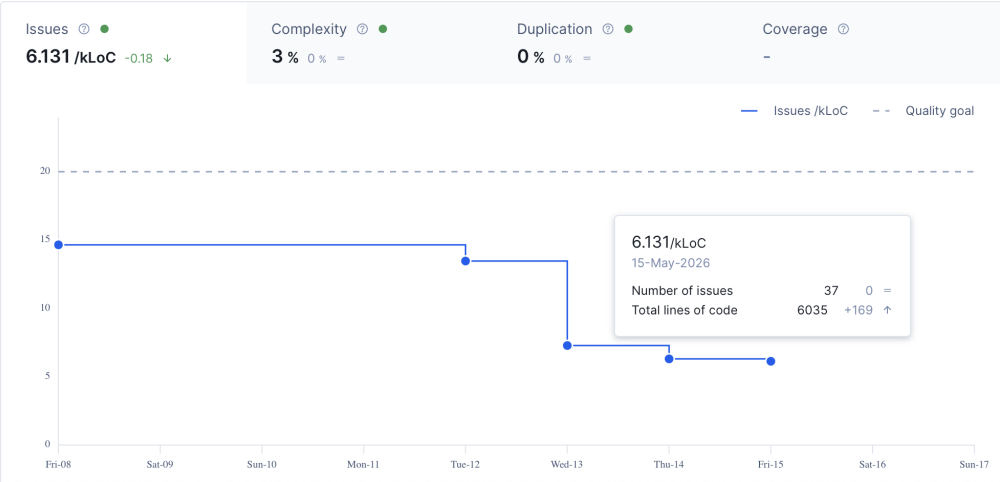


Figure 6: Codacy quality evolution of codebase

1.3.3 CodeQL

CodeQL scans all our C# files and analyzes them for security vulnerabilities. Currently no security vulnerabilities have been found.

1.3.4 Trivy

TrivyScanner scans our Dockerfiles for misconfigurations. Figure 7 shows the report summary for misconfigurations in the latest scan. Currently we have one misconfiguration that we haven't found a fix for yet, which is caused by our MySQL dockerfile being run with root instead of a non-root user. From our initial research, it seems like this might not be easily possible with the MySQL 8.0 base image that we have chosen, so we have not managed to fix this issue yet.

Target	Type	Misconfigurations
Dockerfile-minitwit	dockerfile	0
Dockerfile-minitwit-api-tests	dockerfile	0
Dockerfile-minitwit-tests	dockerfile	0
Dockerfile-minitwit-ui-tests	dockerfile	0
Dockerfile-mysql	dockerfile	1
logging/elasticsearch/Dockerfile	dockerfile	0
monitoring/grafana/Dockerfile	dockerfile	0
monitoring/prometheus/Dockerfile	dockerfile	0

Figure 7: Report from TrivyScanner on Dockerfile misconfigurations

After scanning for misconfigurations TrivyScanner builds the Docker images and scans each image for vulnerabilities. Currently two of our images have vulnerabilities, minitwit-test and minitwit-mysql. Figure 8 shows the report of the vulnerabilities in the minitwit-test Docker image. Appendix 5.2 contains summary of vulnerabilities found in the minitwit-mysql image. The issues in the minitwit-mysql stem from the MySQL 8.0 base image as well, but are not necessarily relevant for our system in it's current state, as the image on our production database can only be accessed by our minitwit service, which runs neither python or golang, which are the packages the vulnerabilities affect.

If we had more time, we would have assigned someone the task of going through all the issues from SonarQube Cloud, Codacy and Trivy when setting up the tools in order to get the initial number of issues lowered. However, we have tried to fix issues continuously if they got reported during our CI pipeline for a pull request.

2 Process' Perspective

This perspective should clarify how code or other artifacts come from idea into the running system and everything that happens on the way.

In particular, the following descriptions should be included:

- A complete description and illustration of stages and tools included in the CI/CD pipelines, including deployment and release of your systems.
- How do you monitor your systems and what precisely do you monitor?
- What do you log in your systems and how do you aggregate logs?
- Brief description of how you security hardened your systems.
- How do you handle availability and scaling in your systems?

```
minitwit-minitwit-tests:latest (debian 13.4)
============================================
Total: 4 (HIGH: 4, CRITICAL: 0)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
libcap2	CVE-2026-4878	HIGH	affected	1:2.75-10+b8		libcap: libcap: Privilege escalation via TOCTOU race condition in cap_set_file() https://avd.aquasec.com/nvd/cve-2026-4878
libsystemd0	CVE-2026-29111			257.9-1~deb13u1		systemd: systemd: Arbitrary code execution or Denial of Service via spurious IPC... https://avd.aquasec.com/nvd/cve-2026-29111
libtinfo6	CVE-2025-69720			6.5+20250216-2		ncurses: ncurses: Buffer overflow vulnerability may lead to arbitrary code execution. https://avd.aquasec.com/nvd/cve-2025-69720
libudev1	CVE-2026-29111			257.9-1~deb13u1		systemd: systemd: Arbitrary code execution or Denial of Service via spurious IPC... https://avd.aquasec.com/nvd/cve-2026-29111

Figure 8: Report from TrivyScanner on Docker image minitwit-tests

2.1 CI/CD

For our CI/CD pipelines we decided to use GitHub Actions, since our codebase is hosted on GitHub and it then seemed like the simplest option to get started, compared to using external pipeline services. We have created several workflows that run based on different event triggers. As mentioned in section 1.1, we have both a production environment and an identical test environment; both of them are used in our CI/CD pipelines.

Our CI pipeline is triggered on a pull request to main and includes both code analysis and automated testing. If the tests pass, a new image of the MiniTwit application is pushed to DockerHub and deployed to the test environment. This allows us to manually verify that the new changes from the PR integrate well into our existing application, and lowers the likelihood of unexpected issues when these changes are deployed to production.

Our CD pipeline is triggered by a push to main. This pipeline includes the same steps as our CI pipeline, except that the final step now deploys the MiniTwit image to production environment. This means our system is continuously deployed to production whenever changes have been reviewed and pass several checks.

In Figure 9, a simplified diagram of the CI/CD pipeline is shown. Only the names of the stages are shown, the steps executed in each workflow are not included here.

In Figure 10 is an illustration of the automated testing workflow. This workflow is reused in both the workflow for deployment to test environment and the one for deployment to production environment.

Figure 11 illustrates the workflow that deploys to production environment. As mentioned before, it uses the workflow for tests shown in figure 10.

The workflow for deploying to test environment is very similar to Figure 11, an illustration is included in appendix 5.1. Illustrations of the workflows for CodeQL, SonarQube and Trivy can be found in the same place.

We also have a workflow for creating a draft for a new release. It is triggered whenever a new versioning tag is pushed. We would have liked to improve this workflow by finding some way to automate more of it, since it right now requires manual interference both for creating and pushing a tag, and then reviewing and publishing the release. This workflow is illustrated in appendix 5.1.

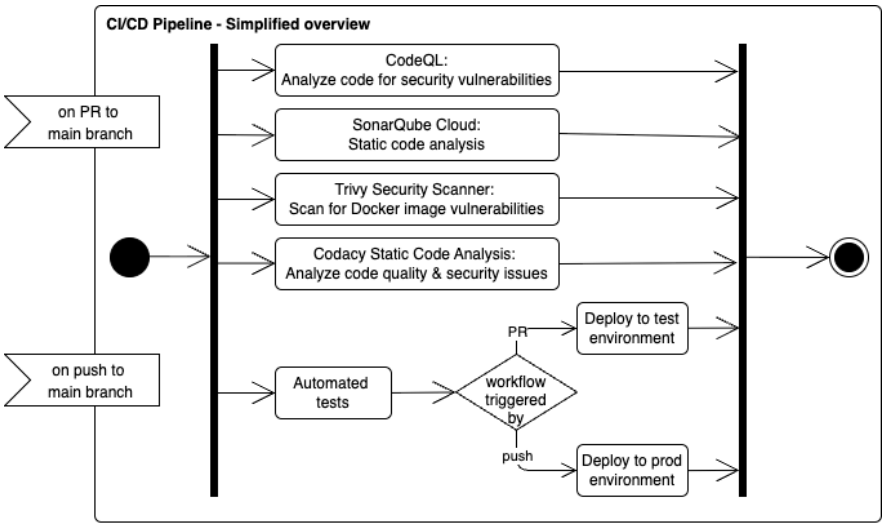


Figure 9: Simplified CI/CD pipeline with no individual workflow steps shown

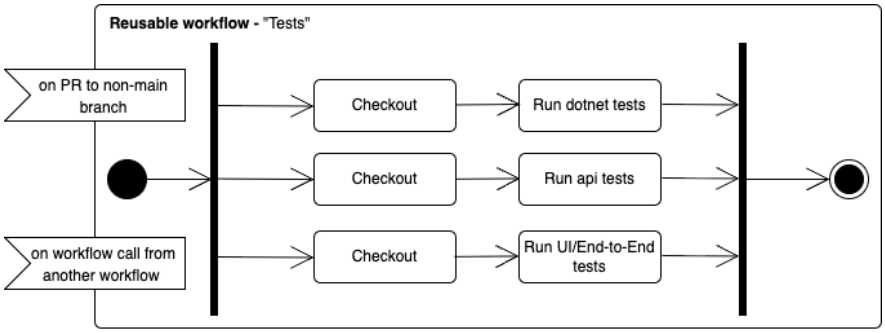


Figure 10: Workflow running automated tests

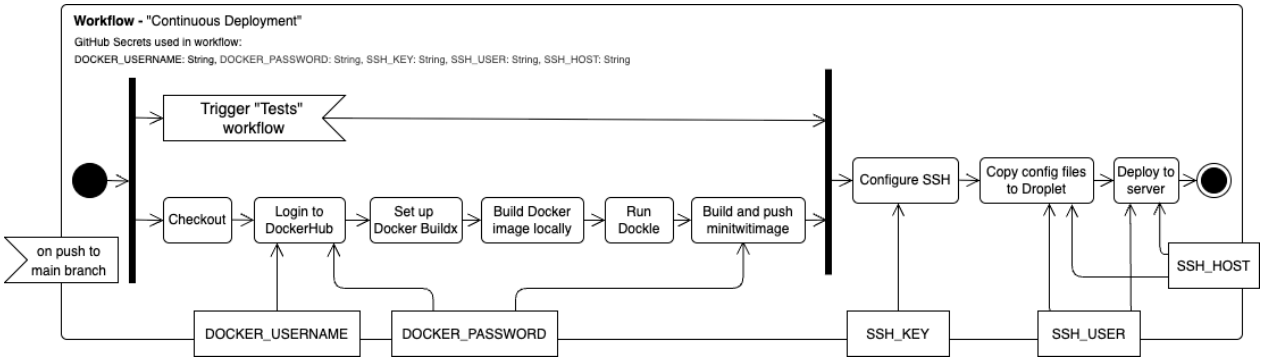


Figure 11: Workflow testing and deploying to production

We have also set up a workflow with Pandoc which generates a new PDF for the report on every PR and push to main where changes have been made in the /report folder. This is also illustrated in appendix 5.1.

2.2 Monitoring

Figure 12 is a sequence diagram showing the process of collecting, forwarding, and visualizing application metrics in the monitoring system.

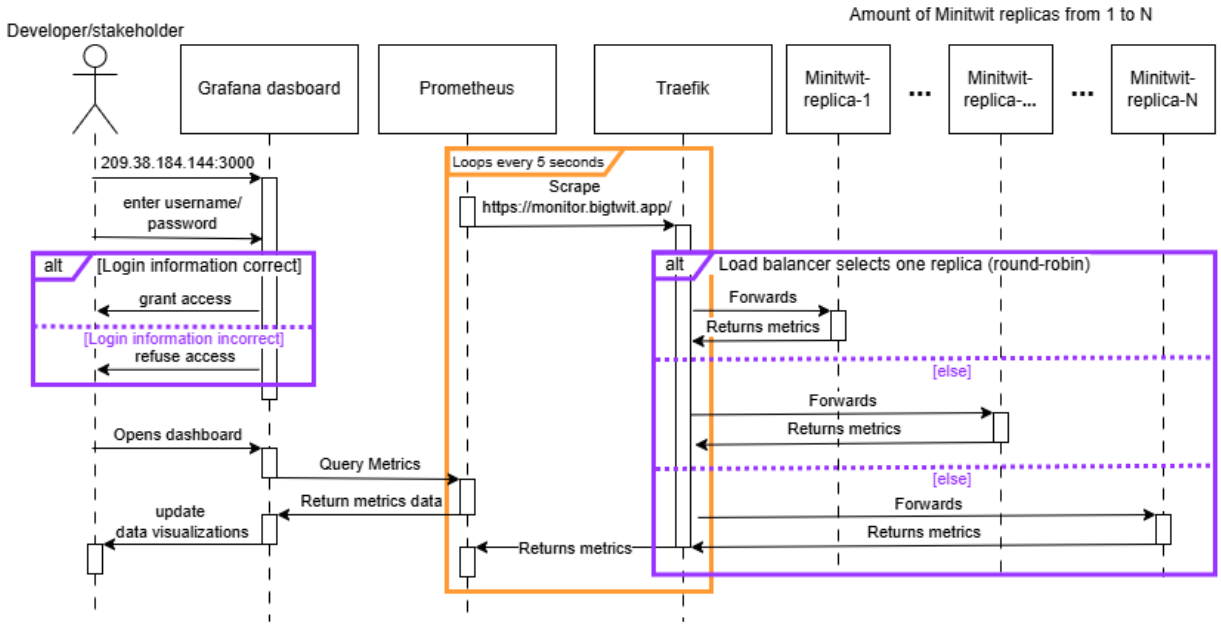


Figure 12: A sequence diagram of how monitoring works for Minitwit

To ensure we do not leak information on our metrics of Minitwit, we have set a username and password on Grafana, that is automatically set on creation. In addition to this, only the Monitor's droplet IP adress is whitelisted to scrape https://monitor.bigtwit.app/, done via Traefik, so no other attacker would be able to access this information.

On this metrics endpoint we use `app.UseHttpMetrics();`, which writes things to the endpoint such as total amount of HTTP requests received, the duration of these requests, and more HTTP specific metrics. In addition to this, we added 2 "gauges" to the metrics, that showed the amount of tweets and users the app has. This data is cached, so if another metrics request is received in less than 30 seconds, we re-use the old data for tweets, and followers. This is done to not overwork the database, with requests to count the total amount of tweets and users.

As can be seen in Figure 13 and Figure 12, we have a hybrid of push/pull monitoring, as Minitwit pushes some internal data to a metrics endpoint, and Prometheus pulls from this endpoint.

As can be seen in the Figure 12, Traefik load balances between each container, which creates this fluctuating graph, that can be seen in Figure 14 and Figure 15 and Figure 16 and Figure 19 under here, due to Prometheus not knowing exactly what container it has scraped, and can therefore not make an average.

To mitigate this error, we should have moved our Prometheus container from its' own droplet to the Manager droplet, and then from here it would be able to scrape all the individual replicas, and find averages over these, via the Docker network, and communicate this to Grafana on the monitoring droplet. However, this would still be a problem due to the workers being on different droplets than the manager, therefore we would

```
// Before collecting metrics, we want to update the total amount of tweets and users,
// so we get the latest values when scraping
DateTime _lastUpdate = DateTime.MinValue;
Metrics.DefaultRegistry.AddBeforeCollectCallback(async (cancel) =>
{
  if ((DateTime.Now - _lastUpdate).TotalSeconds < 30) return; // Skip if too recent
  //The DbContext is a scoped service, so we need to create a scope to get it
  using (var scope = app.Services.CreateScope())
  {
    var context = scope.ServiceProvider.GetRequiredService<MinitwitContext>();

    // Query the database for the absolute latest numbers
    var totalTweets = await context.Messages.CountAsync(cancel);
    var totalUsers = await context.Users.CountAsync(cancel);

    // Update the Gauges
    MinitwitMetrics.TotalTweets.Set(totalTweets);
    MinitwitMetrics.TotalUsers.Set(totalUsers);
    _lastUpdate = DateTime.Now;
  }
});
```

Figure 13: The source code for caching, in the metrics

need a package that could discover the exact location of each replica, for example the (prometheus-docker-sd package).

In addition to this we also wanted to monitor all of our services, i.e. not "just" the webservice, but also the database, to make it easier to determine where an error/bottleneck is located, however we did not get to implement this.

Due to us developers not wanting to constantly monitor our system, we have set up an *Uptime Check*, that monitors our droplets, and gives everyone in the team a notification if:

- https://bigtwit.app is down
- there is latency over 1000ms when accessing https://bigtwit.app
- The SSL certificate of bigtwit.app is about to expire.(However Traefik should automatically renew this certificate, before it expires.)

In addition to this we have added a ressource alert, that monitors our test database and production database, to see when it crosses over 70% CPU in over 5 minutes, which could indicate an attack, or a rapid increase in requests that it maybe cannot handle.

2.2.1 Dashboards

To see the dashboard shown in Figures 14,15,16,17,18,19, go to 46.101.69.11:3000, where the dashboard and logs can be viewed. The credentials are specified in the post made by Helge.

We made 2 different dashboards, one made with a developer focus (Infrastructure Health), and one made with a Business stakeholder focus(Product Performance).

2.2.1.1 Minitwit Infrastructure Health Dashboard

In Figure 14,15,16, are the images of the dashboard and descriptions of the information it provides for the developers:

- Immediate Root Cause Analysis: If the Status is UP but the Error Rate is spiking, developers know the app is running but the code or database is failing.
- Capacity Planning: Requests per second and Total Requests help developers understand if the current infrastructure (CPU/RAM) can handle the load or if they need to scale.

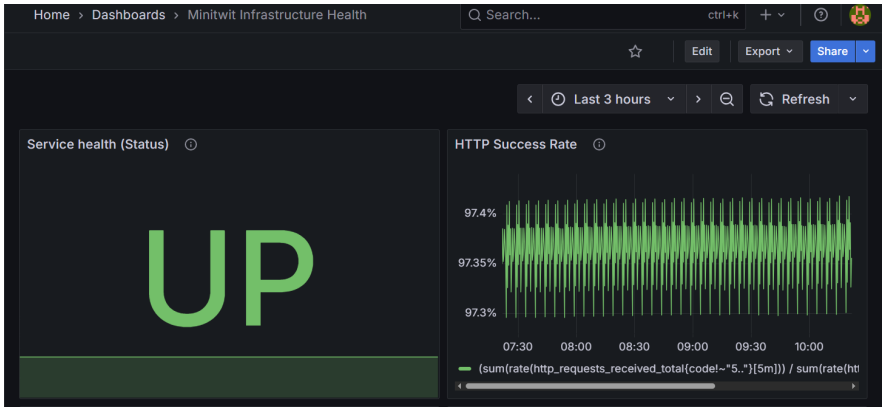


Figure 14: Minitwit Infrastructure Health dashboard - Service health and HTTP Success Rate

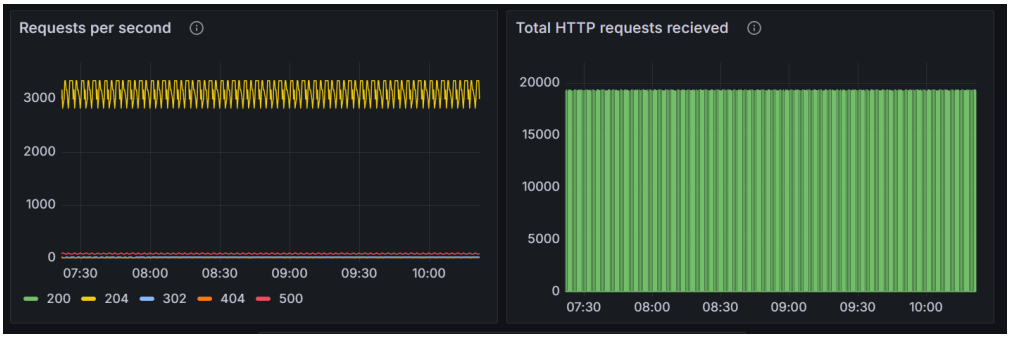


Figure 15: Minitwit Infrastructure Health dashboard - Requests per second and Total HTTP requests received

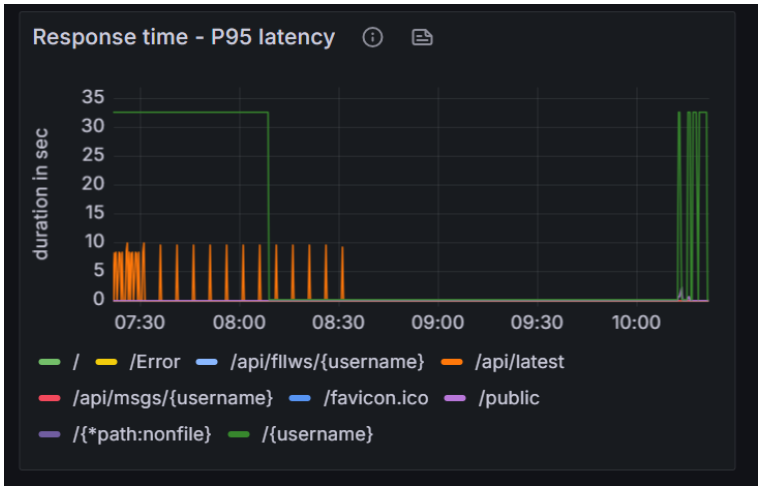


Figure 16: Minitwit Infrastructure Health dashboard - Response time (P95 latency)

- Performance Regressions: By monitoring Latency(P95) and HTTP Success rate, developers can see if a recent code deployment made the app slower, even if it didn't *break* it.

We have, in the source code, created a */healthz* endpoint, that shows when Minitwit is up and running, however this is only used for spinning up the system locally with docker compose. Our dashboard's health check is currently based on whether or not Prometheus was able to scrape the target, this should instead be based on the */healthz* endpoint to seperate it from Prometheus.

2.2.1.2 Minitwit Product Performance Dashboard

In Figure 17,18,19, are images of the dashboard and descriptions of the information it provides the business stakeholders:

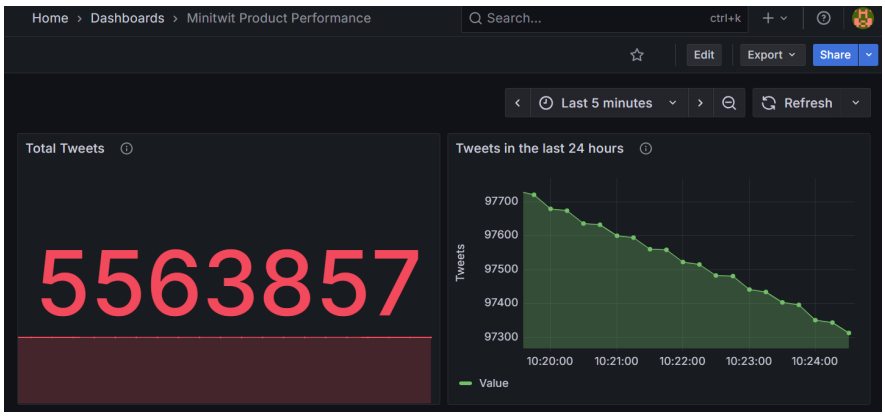


Figure 17: Minitwit Product Performance dashboard - Tweet overview

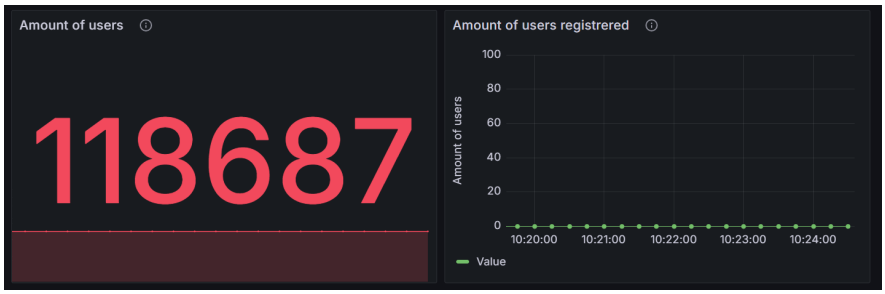


Figure 18: Minitwit Product Performance dashboard - User overview

- KPI Tracking: "Total Tweets" and "amount of users" are direct Key Performance Indicators. In a real application, if registrations drop to zero, the Marketing or Product team needs to know immediately.
- Engagement Trends: The 24-hour tweet increase shows the pulse of the community. A sudden drop might indicate a trend issue or a subtle bug that doesn't trigger an error but prevents posting. The amount of users registerered in the last hour, can be used to analyze if a campaign or trend has had impact or not.
- User Satisfaction: Slow apps lead to lost users, so we include an overview of the latency of HTTP requests to keep the business aligned with the need for technical optimization.

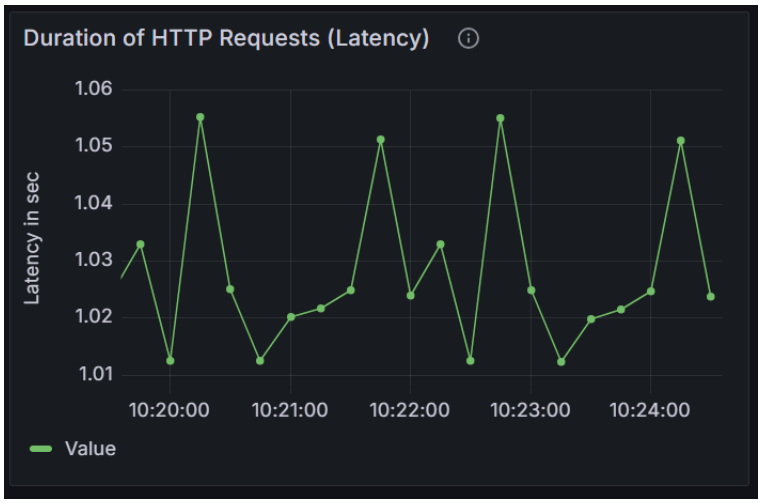


Figure 19: Minitwit Product Performance dashboard - Duration of HTTP Requests (Latency)

2.3 Logging

Logs from MiniTwit uses a Push-based model, where Serilog directly pushes logs to Elasticsearch. Since Serilog is directly implemented in MiniTwit, this means all MiniTwit replicas are pushing logs to Elasticsearch, where they are collected and displayed in a singular view. Our default logging level is configured to be *Information*, i.e any logs from the MiniTwit application will be logged if it is at the information level or above. We override this for Microsoft, AspNetCore and EFCore where we only log *Warning* and above. MiniTwit logs use the *minitwit-logs* index prefix, making them easy to distinguish from other logs.

2.3.1 What our current logging implementation is missing

Since our infrastructure is running in docker containers, we should also have set up a log-shipper, such as Filebeat, to collect docker container logs and ship them to Elasticsearch.

Furthermore, our actual logging statements in MiniTwit.cs are also quite sparse, with some functions not actually logging anything. Whilst not everything needs to be logged, this should be a more deliberate choice than it is currently.

2.4 Security

Security in our system is enforced on several layers.

We've configured a DigitalOcean firewall for our database, following a default-deny principle, i.e all inbound traffic is blocked, unless manually stated otherwise. Inbound traffic is allowed for SSH on port 22, and droplets with the minitwit-swarm tag on DO is allowed for MySQL on port 3306

Our droplets all have UFW set up, also following a default-deny principle for incoming traffic. During setup of the droplets, the configuration scripts opens specific ports for inbound traffic. The configuration scripts also updates the default ssh settings, limiting retries, reducing the graceperiod and disabling password authentication.

For transport security, we use Let's Encrypt to provision SSL/TLS certificates, ensuring that communication between clients and the application is encrypted over HTTPS. Furthermore we ensure that attempts to access the site through HTTP is redirected to a secure HTTPS connection.

On the application level, we enforce security through frameworks implemented in the codebase. Database access is handled through Entity Framework, which uses parameterized queries to help prevent SQL injection

attacks. Razor Pages automatically encodes all HTML, which protects against cross site scripting (XSS) from malicious users. For users of the minitwit application passwords are encrypted using PBKDF2 with salting, which ensures that passwords are securely stored, and safe from brute force attacks. Our code base has .NET analyzers, which picks up on security diagnostics, and our .editorconfig file ensures that any security issues discovered through analysers will be marked as errors, meaning the application will fail to build, if a security issue is present.

Within our CI/CD pipeline we have have two security tools, Trivy for Dockerfiles and images, and CodeQL for static analysis of the codebase. Trivy is run in its own workflow, which scans for misconfigurations in all Dockerfiles present in the repository. It then builds the images and scans for vulnerabilities in those. If any misconfigurations or vulnerabilities are found, it will fail the workflow. CodeQL runs in its own workflow, which scans the codebase by running a set of queries to find common vulnerabilities in the code base. Both workflows runs when a pull request to main is created, on push to main, and each week on Monday. Running both workflows on a schedule, rather than just on PR and push is relevant, since new vulnerabilities can be discovered any time, and therefore code that was thought to be secure when the code was pushed, may be discovered to be insecure. The weekly workflow helps ensure that we become aware of newly discovered vulnerabilities.

In addition to the things discussed in this chapter, we also did a Security Assesment of our current system, to determine where we should put our effort, in terms of security, if we had more time to do this project. This can be found in the appendix, in the section Risk Assesment .

2.5 Availability

To ensure availability of our application, we use Docker Swarm for orchestration and Traefik as a reverse proxy and load balancer, across DO droplets.

Docker Swarm enables us to run replicated services across several nodes, ensuring that if one container or droplet fails, another instance continues serving requests. The size of our Swarm is defined in our Vagrant file, and is one manager, with two workers. In the compose_stack we define the desired amount of replicas we want for the minitwit service. Docker Swarm continuously monitors the desired state, so that if a container crashes, it automatically starts a new instance to replace it. The extra replicas ensures that the application remains available even during container failures.

Traefik distributes incoming request evenly across the services, such that no service gets overworked. If a container fails, Traefik detects that it is no longer available and stops routing requests to it, ensuring requests don't get sent to unavailable services.

2.5.1 Scalability

In our setup scalability is manual, where horizontal scalability can be achieved by increasing the size of our Swarm in the Vagrant file, as well as the amount of replicas in the compose_stack. Vertical scaling can be achieved by increasing the resources of existing droplets on DO.

3 Reflection Perspective

Describe the biggest issues, how you solved them, and which are major lessons learned with regards to:

- evolution and refactoring
- operation, and
- maintenance

of your ITU-MiniTwit systems. Link back to respective commit messages, issues, tickets, etc. to illustrate these.

Also reflect and describe what was the "DevOps" style of your work. For example, what did you do differently to previous development projects and how did it work?

3.1 Evolution and Refactoring

Remember to write about how changing from one docker container, to using Docker swarm destroyed our old way of monitoring. (OBS! we have written something about monitoring, so just a quick comment on how this destroyed it.)

3.2 Operation

3.3 Maintenance

4 Use of AI

ITU's rules on the use of generative AI apply for this report too. They are described here and in detail here. Please follow them. For your report that means that you have to state which generative AI tools have been used for which task(s) in your projects. Additionally, describe how generative AI tools have been used and briefly reflect and discuss how they supported or hindered your work process.

5 Appendix

5.1 Appendix for CI/CD workflows

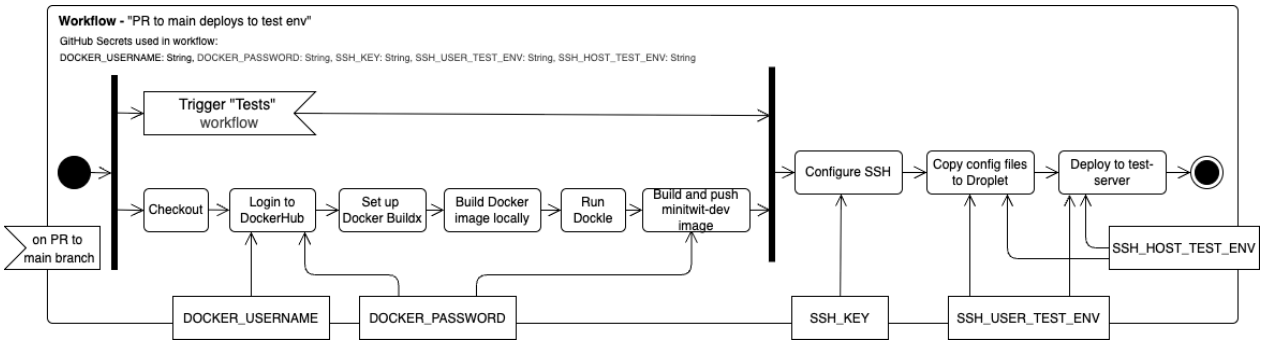


Figure 20: Workflow testing and deploying to test environment

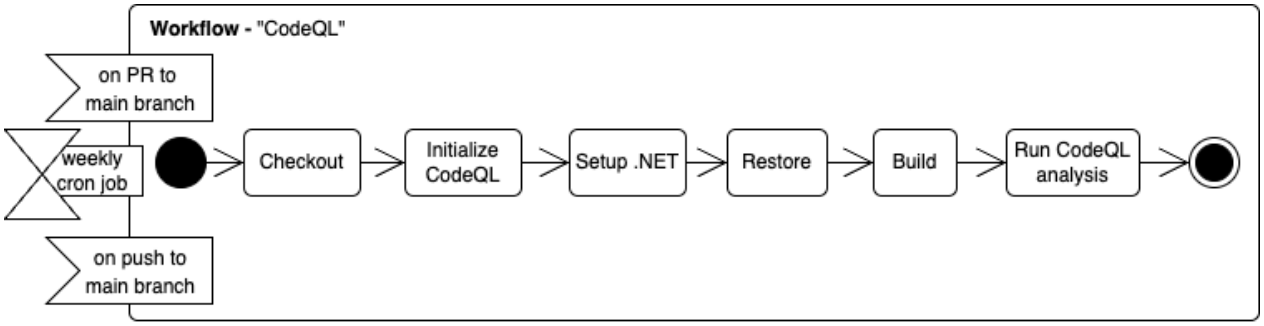


Figure 21: Workflow for CodeQL

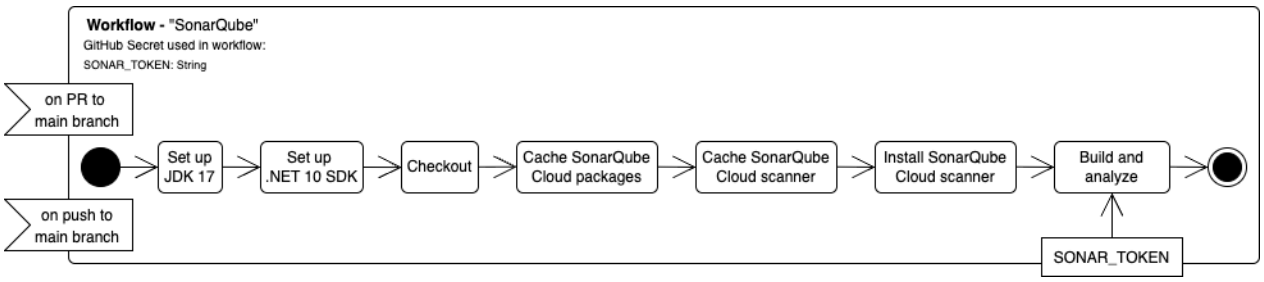


Figure 22: Workflow for SonarQube

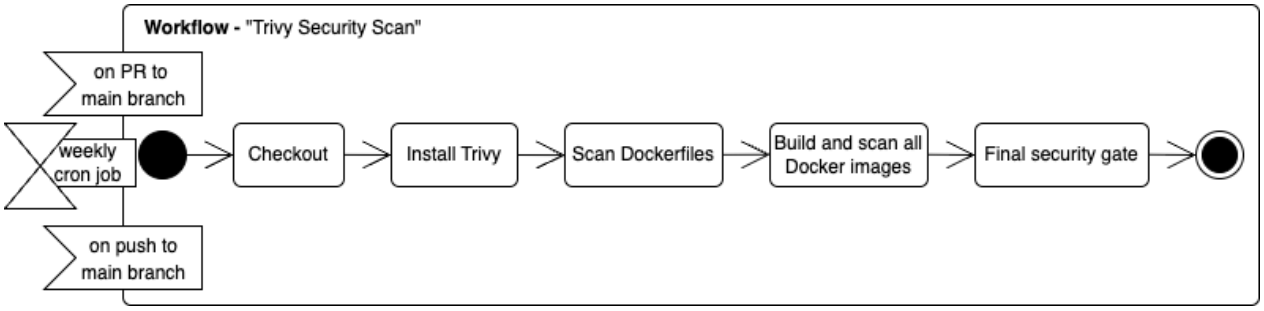


Figure 23: Workflow for Trivy

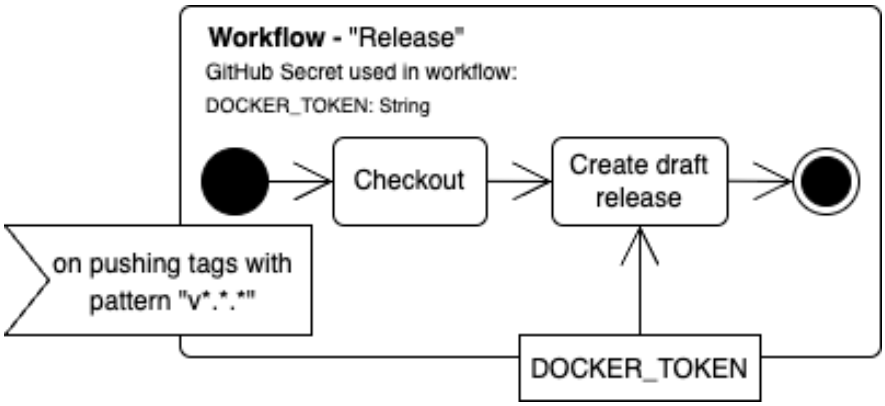


Figure 24: Workflow for drafting release

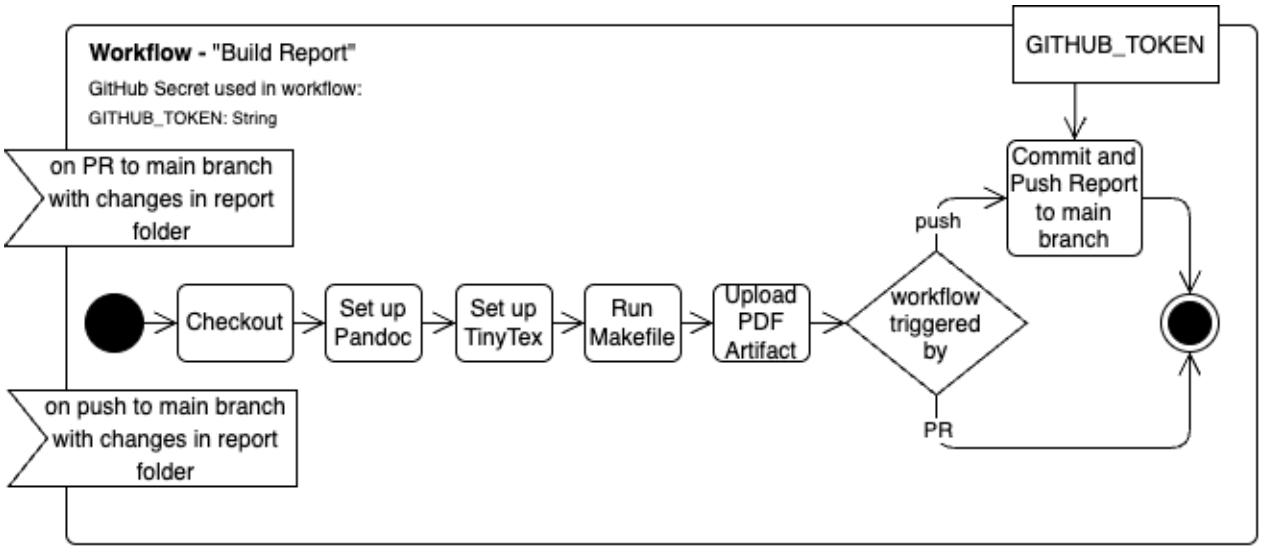


Figure 25: Workflow for generating report

5.2 Appendix for TrivyScanner summary of minitwit-mysql image vulnerabilities

```
Python (python-pkg)
===================
Total: 3 (HIGH: 3, CRITICAL: 0)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
pyOpenSSL (METADATA)	CVE-2026-27459	HIGH	fixed	25.3.0	26.0.0	pyOpenSSL: DTLS cookie callback buffer overflow https://avd.aquasec.com/nvd/cve-2026-27459
urllib3 (METADATA)	CVE-2026-44431			2.6.3	2.7.0	urllib3 is an HTTP client library for Python. From 1.23 to before... https://avd.aquasec.com/nvd/cve-2026-44431
	CVE-2026-44432					urllib3 is an HTTP client library for Python. From 2.6.0 to before... https://avd.aquasec.com/nvd/cve-2026-44432

Figure 26: Python package vulnerabilties for minitwit-mysql image

5.3 Risk Assesment

5.3.1 Risk identification

5.3.1.1 Assets

- Web application
- Web API
- Grafana dashboard
- Prometheus instance
- Database

5.3.1.2 Threat Sources

- Cookie manipulation.
- Root-user on Docker images
- DDOS attacks on our webpage, due to no limit on amount of requests.
- SQL injection on our web page.
- SSH attack on our server.

5.3.1.3 Risk Scenarios

1. Attacker performs SQL injection on web application to download sensitive user data.
2. Attacker downs our website by using DDOS attacks on our webpage.
3. Attacker connects to one of our droplets via SSH attacks.
4. Attacker connects to our database and requires ransom to get the data back.
5. Attacker manages to guess the credentials for the API, and uses them to perform a DDOS attack.
6. Attacker escalates privileges or impersonates another user, via cookies.
7. Attacker gets access to Grafana and gets access to important information through metrics.

```
usr/local/bin/gosu (gobinary)
==============================
Total: 14 (HIGH: 13, CRITICAL: 1)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
stdlib	CVE-2025-68121	CRITICAL	fixed	v1.24.6	1.24.13, 1.25.7, 1.26.0-rc.3	crypto/tls: crypto/tls: Incorrect certificate validation during TLS session resumption https://avd.aquasec.com/nvd/cve-2025-68121
	CVE-2025-58183	HIGH			1.24.8, 1.25.2	golang: archive/tar: Unbounded allocation when parsing GNU sparse map https://avd.aquasec.com/nvd/cve-2025-58183
	CVE-2025-61726				1.24.12, 1.25.6	golang: net/url: Memory exhaustion in query parameter parsing in net/url https://avd.aquasec.com/nvd/cve-2025-61726
	CVE-2025-61728					golang: archive/zip: Excessive CPU consumption when building archive index in archive/zip https://avd.aquasec.com/nvd/cve-2025-61728
	CVE-2025-61729				1.24.11, 1.25.5	crypto/x509: golang: Denial of Service due to excessive resource consumption via crafted... https://avd.aquasec.com/nvd/cve-2025-61729
	CVE-2026-25679				1.25.8, 1.26.1	net/url: Incorrect parsing of IPv6 host literals in net/url https://avd.aquasec.com/nvd/cve-2026-25679
	CVE-2026-32280				1.25.9, 1.26.2	crypto/x509: crypto/tls: golang: Go: Denial of Service vulnerability in certificate chain building... https://avd.aquasec.com/nvd/cve-2026-32280
	CVE-2026-32281					crypto/x509: golang: Go crypto/x509: Denial of Service via inefficient certificate chain validation... https://avd.aquasec.com/nvd/cve-2026-32281
	CVE-2026-32283					crypto/tls: golang: Go crypto/tls: Denial of Service via multiple TLS 1.3 key... https://avd.aquasec.com/nvd/cve-2026-32283
	CVE-2026-33811				1.25.10, 1.26.3	When using LookupCNAME with the cgo DNS resolver, a very long CNAME... https://avd.aquasec.com/nvd/cve-2026-33811
	CVE-2026-33814					When processing HTTP/2 SETTINGS frames, transport will enter an infini ... https://avd.aquasec.com/nvd/cve-2026-33814
	CVE-2026-39820					Well-crafted inputs reaching ParseAddress, ParseAddressList, and Parse ... https://avd.aquasec.com/nvd/cve-2026-39820
	CVE-2026-39836					Panic in Dial and LookupPort when handling NUL byte on Windows in... https://avd.aquasec.com/nvd/cve-2026-39836
	CVE-2026-42499					Pathological inputs could cause DoS through consumePhrase when parsing ... https://avd.aquasec.com/nvd/cve-2026-42499

Figure 27: Gosu package vulnerabilties for minitwit-mysql image

5.3.2 Risk Analysis

Here we use the scenarios from above, via the index of them, and determine the likelihood and impact of each of the scenarios.

5.3.2.1 Determine likelihood

1. Low - because we use EF-Core, which automatically parameterizes queries and escapes all input strings. As long as all database access goes through EF-Core and not raw SQL queries to the database, the probability of a successful SQL injection is very low.
2. High - We have not set any rate limiting on our page, so all people would be able to pretty easily create a bot that would DDOS attack us.
3. Low - an attacker would need a compromised private key or exploit an unknown SSH vulnerability, both of which are much harder.
4. Low - same reasons as for number 3.
5. High - these credentials are hardcoded in our source code, for the API, so an attacker would easily be able to see what the credentials are, and how they should be encoded.
6. Medium - The session cookies are encrypted via HTTPS, and expires after 15 minutes, so an attacker should be quick to use it.
7. High - As the credentials are the ones Helge has posted on the Teams group, several other students of this course have access to it, and we do not know if Helge, Mircea or another student is spreading these credentials around.

5.3.2.2 Determine impact

1. High - could expose user data, and credentials.
2. High - could prevent users from acessing our site, lowering the customer satisfaction.
3. High - An attacker would be able to change our program, stop it, or create a backdoor to our system.
4. High - An attacker could steal our data and demand ransom, which would damage our users and our reputation.
5. High - could prevent users from acessing our site, lowering the customer satisfaction.
6. Medium - could impersonate other users and write things they do not want. However because all users have the same priveliges, it would not be more severe than this.
7. Medium - An attacker could gain access to our log/monitoring data, however these are not as sensitive as e.g. our secrets or user data. They could also change or delete our dashboard views, but these can be restored. In addition to this, an attacker would be able to determine the design of the system, error codes, and latency of different requests, which is not something you want an adversary to know, as this can be the basis for a roadmap to attack our system.

5.3.2.3 Risk Matrix to prioritize risk of scenarios

	Low likelihood	Medium likelihood	High likelihood
High impact	**1.** SQL injection **3.** SSH attack **4.** ransom attack	-	**2.** DDOS attack **5.** guess credentials for API to DDOS
Medium impact	-	**6.** cookie exploitation	**7.** Access to Grafana
Low impact	-	-	-

5.3.2.4 What we could do to mitigate some of these scenarios

1. Already mitigated, also CI-CD pipeline check for security vulnerabilities.
2. Use Traefik support for setting up rate limiting.
3. Already mitigated.
4. We would need to ensure that our keys are not stolen/shared to an attacker.
5. Same solution as to 2. And then saving the credentials in a secret.
6. Use Token-based authentication instead.
7. Create new credentials only our team knows of, and set-up 2 factor authentication.